SAAS MULTICLÍNICA

# Matriz de perfis e permissões

Acessos por perfil, operações CRUD, módulos contratados e regras de isolamento aplicadas pela API, com a visibilidade atual da interface.

**6**
perfis existentes

**34**
operações representativas testadas

**204**
verificações de autorização

**146**
rotas inventariadas

**Tenant-scoped**
Dados limitados à clínica selecionada.

**Plano Parcial**
Módulos não contratados retornam 403 (exceto administradores).

**Escopo médico e de equipe**
Registros seguem vínculos, grupos e equipe.

**SuperAdministrador**
Cria, desativa e alterna clínicas.

PERFIS DA APLICAÇÃO

# Quem pode fazer o quê na API?

C = cadastrar · R = visualizar · U = alterar · D = excluir/desativar. "Escopo" significa que o usuário só alcança registros relacionados a ele, ao seu grupo médico ou à sua equipe.

**Administrador**
Administração operacional de uma clínica.

**Médicos**
Atendimento e dados clínicos no escopo médico.

**Pacientes**
Acesso pessoal limitado.

**Controller**
Operação clínica e financeira, sem administração geral.

**SuperAdministrador**
Administração da plataforma e troca de clínica.

**Equipe**
Identidade coletiva com operador identificado e auditado.

| Recurso | Administrador | Médicos | Pacientes | Controller | SuperAdministrador | Equipe |
|---|---|---|---|---|---|---|
| Dashboard | R | R | R | R | R | R |
| Clínicas (/api/platform/clinicas) | R/U da própria + equipes | — | — | — | CRUD + troca | — |
| Auditoria da plataforma | — | — | — | — | R | — |
| Sessões ativas da plataforma | — | — | — | — | R | — |
| Usuários | CRUD | R/U próprio | R/U próprio limitado | R próprio | CRUD | R membros |
| Resetar senha de terceiro | Sim | — | — | — | Sim | — |
| Equipes (/api/equipes) | CRUD | — | — | — | CRUD | Trocar PIN próprio |
| Pacientes e cirurgias | CRUD | CRUD · escopo | R próprio | CRU | CRUD | CRU · escopo |
| Pendências de cadastro de pacientes (ano da consolidação) | R clínica | R · escopo | — | R clínica | R clínica | — |
| Arquivos de pacientes | CRD | CRD · escopo | R próprios | CRD | CRD | CRD · escopo |
| Observações de pacientes | CRU | CRU · escopo | — | CRU | CRU | CRU · escopo |
| Faturamento médico | R clínica | R · escopo | — | R clínica | R clínica | R · escopo |
| Histórico de arquivos do faturamento | CRD | R · escopo | — | CRD | CRD | R · escopo |
| Atendimentos cirúrgicos | CRUD | CRUD · escopo | — | CRUD | CRUD | — |
| Faturamentos, glosas e recursos | CRUD | R · escopo | — | CRUD | CRUD | — |
| Contas a receber e recebimentos | CRUD | — | — | CRUD | CRUD | — |
| Relatórios e auditoria financeira | R | — | — | R | R | — |
| Preços por convênio | CRUD | R | — | CRUD | CRUD | — |
| Grupos médicos | CRUD | — | — | CRUD | CRUD | — |
| Agenda e notificações | CRUD clínica | CRUD próprio/escopo | CRUD próprio | CRUD próprio | CRUD clínica | CRUD · escopo |
| CBHPM | R + importar | R | R | R | R + importar | R |
| Hospitais, convênios e OPME | R | R | R | R | R | R |
| Licença própria | R | R | R | R | R | R |
| Licenças de médicos | R/U/liberar | — | — | — | R/U/liberar | — |
| Exportações (POST /api/exports) | Solicitar | Solicitar · escopo | Solicitar · próprio | Solicitar | Solicitar | Solicitar · escopo |
| Monitoramento (erros e segurança) | R/limpar da clínica | — | — | — | R/limpar todas | — |
| Aceites legais e privacidade | Próprios | Próprios | Próprios | Próprios | Próprios | Próprios |
| Identidade visual pública | R | R | R | R | R | R |

● permitido ● permitido com limite/escopo ● negado ● função exclusiva de plataforma

EXPERIÊNCIA DO USUÁRIO

# Itens exibidos no menu

"Licença" depende da feature correspondente. Todos os itens operacionais dependem do módulo contratado no plano Parcial; na interface só o SuperAdministrador ignora essa restrição.

| Item visual | Administrador | Médicos | Pacientes | Controller | SuperAdministrador | Equipe |
|---|---|---|---|---|---|---|
| **Painel** | Sim | Sim | Licença | Licença | Sim | Licença |
| **Pacientes** | Sim | Sim | Leitura | Licença | Sim | Licença |
| **Faturamento médico, histórico e relatórios** | Sim | Sim | — | Sim | Sim | Sim |
| **Grupos médicos** | Sim | — | — | Sim | Sim | — |
| **Agenda e notificações** | Sim | Sim | Sim | Sim | Sim | Sim |
| **Usuários** | Sim | — | — | — | Sim | Sim |
| **Meu cadastro** | — | Sim | Sim | — | — | — |
| **Clínicas** | Própria | — | — | — | Sim | — |
| **Configuração** | Sim | — | — | — | Sim | — |
| **Tutoriais interativos** | Sim | Sim | Sim | Sim | Sim | Sim |

## Regra de exclusão

- Clínica: desativação lógica, somente SuperAdministrador.
- Usuários: somente Administrador e SuperAdministrador.
- Pacientes: Administrador, SuperAdministrador e Médico no escopo.
- Evento: o proprietário gerencia o próprio; administradores gerenciam a clínica.

## Regras que sempre se acumulam

- O usuário somente acessa dados da clínica selecionada na sessão (ClinicaId do JWT); consultas sem clínica resolvida falham fechadas.
- No plano Parcial, rotas de usuários, pacientes (inclui CBHPM, hospitais, convênios e OPME), faturamento médico, grupos médicos e agenda exigem o módulo contratado e retornam 403 quando ausente. Administrador e SuperAdministrador não são bloqueados por essa regra na API.
- Assinatura suspensa, cancelada ou vencida e licenças individuais de médicos podem bloquear funcionalidades licenciadas (Dashboard.Visualizar, Pacientes.Visualizar, Pacientes.Gerenciar, Cbhpm.Consultar).
- Médicos enxergam pacientes, faturamentos, atendimentos, arquivos, observações e eventos conforme seu vínculo e seus grupos médicos.
- O Administrador permanece restrito à própria clínica, inclusive nas rotas de plataforma; somente o SuperAdministrador cria, desativa e alterna entre clínicas.
- O perfil Equipe usa identidade coletiva; operações sensíveis exigem equipe ativa e operador identificado no token e são auditadas.

ASSINATURA DA CLÍNICA

# Como funciona o plano Parcial

A seleção feita no cadastro da clínica controla a interface e a proteção das rotas da API.

### 1. SuperAdministrador

Seleciona o plano Parcial e marca os módulos contratados no cadastro da clínica.

→

### 2. Sessão da clínica

O login e a troca de clínica recebem a lista efetiva de módulos liberados.

→

### 3. Dupla proteção

Menu e cards são ocultados; chamadas diretas a módulos não contratados recebem 403 (ClinicaModuleAccessMiddleware).

**Usuários**

Rotas /api/users e menu Usuários.

**Pacientes**

Pacientes, CBHPM, hospitais, convênios e OPME.

**Faturamento**

Rotas /api/faturamentos-medicos.

**Grupos médicos**

Quando desmarcado: menu oculto e API retorna 403.

**Agenda**

Quando desmarcado: agenda oculta e API retorna 403.

## Quem não é bloqueado

Na API, Administrador e SuperAdministrador não são bloqueados pelo plano. Na interface, só o SuperAdministrador vê módulos não contratados.

## O que sempre permanece

Painel, autenticação, troca de senha e funções da sessão. Clínicas e Configuração continuam disponíveis ao SuperAdministrador.

## Trial

Todos os módulos previstos ficam disponíveis até “Trial até”, respeitando perfil, escopo e validade da assinatura.

## Completa

Todos os módulos ficam disponíveis até “Assinatura válida até”, respeitando as permissões do perfil.

INTERFACE × API

# Divergências conhecidas e exportações

A API é a fonte de verdade para segurança. A interface pode ser mais restritiva, nunca mais permissiva.

| Situação | Interface | API | Estado |
|---|---|---|---|
| **Médico exclui paciente** | Botão de exclusão só para Administrador/SuperAdministrador | Permite excluir paciente do escopo (PacienteExcluir) | Interface mais restritiva que a API. |
| **Administrador em módulo não contratado** | Oculta o módulo (só o SuperAdministrador ignora o plano) | Administrador e SuperAdministrador não são bloqueados pelo plano | Interface mais restritiva que a API. |
| **Equipe sem operador identificado** | Modo somente leitura | Operações sensíveis exigem operador (EquipeOperacaoSensivel) | Alinhado. |
| **Paciente em Meu cadastro** | Edita nome, telefone, nascimento e foto | PUT próprio preserva e-mail, CPF, perfil, status e dados médicos | Alinhado. |

**Exportações:** todos os perfis podem solicitar POST /api/exports (pacientes, faturamentos-medicos e cbhpm). A API monta o snapshot no servidor com as mesmas queries e o mesmo escopo do perfil; o worker GenerateFileExport apenas gera o arquivo. As telas do front exportam no navegador os dados que a API já filtrou.

## Validação automatizada

**204 verificações** ApiAuthorizationMatrixTests (34 operações × 6 perfis)

**appAccess.test.ts** menu, ações e plano Parcial no front

## Arquivos de referência

**Políticas:** HemodinksAPI.Api/ApiServiceCollectionExtensions.Auth.cs

**Plano:** HemodinksAPI.Api/Middleware/ClinicaModuleAccessMiddleware.cs

**Front:** src/app/appAccess.ts

**Documento detalhado:** docs/MATRIZ_PERFIS_PERMISSOES.md